

W12D4 - Remediation delle vulnerabilità

Studente: Riccardo Luzzi

Corso: Cyber Security

Sistema utilizzato: Kali Linux / Metasploitable

Strumenti utilizzati: Nessus Essentials, Nmap, Netcat, showmount, vncviewer, pfSense

Target: Metasploitable - 192.168.51.101

Introduzione

Dopo la scansione iniziale ho applicato una remediation mirata alle quattro vulnerabilità richieste dalla traccia. Per evitare di limitarmi a nascondere i servizi, nei primi quattro casi ho modificato direttamente la configurazione della macchina Metasploitable. Solo per la quinta prova facoltativa ho utilizzato pfSense, come suggerito dalla consegna, per limitare l'esposizione di rlogin dalla rete di Kali.

Finding	Azione eseguita	Verifica
Bind Shell Backdoor Detection	Disabilitata la voce ingreslock in /etc/inetd.conf.	Nmap: 1524/tcp closed; Netcat: connection refused.
VNC Server 'password' Password	Sostituita la password VNC debole.	Vecchia password rifiutata; nuova password accettata.
NFS Shares World Readable	Rimosso l'export / * da /etc/exports.	showmount senza export; Nmap: No NFS mounts available.
rexecd Service Detection	Disabilitata la voce exec in /etc/inetd.conf.	Nmap: 512/tcp closed.
rlogin Service Detection	Regola Block su pfSense verso 513/TCP.	Nmap: 513/tcp filtered; log firewall conferma il blocco.

1. Bind Shell Backdoor Detection

La prima verifica ha confermato che la porta 1524/TCP espose una bind shell. Nmap identificava il servizio come "Metasploitable root shell" e, collegandomi con Netcat, ottenevo direttamente una shell con uid=0(root), senza autenticazione.

Figura 1 - Prima della remediation: bind shell rilevata sulla porta 1524/TCP

```
(kali@kali)-[~]
└─$ nmap -sV -p 1524 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 03:44 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0018s latency).

PORT      STATE SERVICE      VERSION
1524/tcp  open  bindshell    Metasploitable root shell

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.84 seconds
```

Figura 2 - Accesso alla shell root e individuazione della voce ingreslock in /etc/inetd.conf

```
(kali@kali)-[~]
└─$ nc 192.168.51.101 1524
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/# grep -n "1524\|ingreslock" /etc/inetd.conf
8:ingreslock stream tcp nowait root /bin/bash bash -i
root@metasploitable:/# ps aux | grep inetd
root  4497  0.0  0.1  2424  864 ?        Ss   03:42   0:00 /usr/sbin/xinetd -pidfile /var/run/xinetd.pid -stayalive -inetd_compat
root  4798  0.0  0.1  1784  532 ?        R    03:45   0:00 grep inetd
root@metasploitable:/#
```

La causa era la riga `ingreslock stream tcp nowait root /bin/bash bash -i` presente in `/etc/inetd.conf`. Dopo aver creato una copia di backup del file, ho commentato la riga e riavviato `xinetd`.

```
sudo cp /etc/inetd.conf /etc/inetd.conf.bak
```

```
sudo /etc/init.d/xinetd restart
```

Figura 3 - Riavvio di xinetd e verifica della voce ingreslock commentata

```
msfadmin@metasploitable:~$ sudo /etc/init.d/xinetd restart
* Stopping internet superserver xinetd          [ OK ]
* Starting internet superserver xinetd          [ OK ]
msfadmin@metasploitable:~$ grep -n "ingreslock" /etc/inetd.conf
8:#ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$ _
```

Dopo la modifica la porta 1524 risultava chiusa e Netcat restituiva `Connection refused`. La bind shell non era quindi più raggiungibile dalla macchina Kali.

Figura 4 - Dopo la remediation: porta 1524/TCP chiusa

```
(kali@kali)-[~]
$ nmap -sV -p 1524 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 03:54 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0015s latency).

PORT      STATE SERVICE VERSION
1524/tcp  closed ingreslock

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.70 seconds
```

Figura 5 - Netcat non riesce più ad aprire la bind shell

```
(kali@kali)-[~]
$ nc 192.168.51.101 1524
(UNKNOWN) [192.168.51.101] 1524 (ingreslock) : Connection refused
```

2. VNC Server con password debole

Il servizio VNC era attivo sulla porta 5900/TCP e utilizzava il protocollo VNC 3.3. Il processo Xtightvnc era configurato con il file di autenticazione /root/.vnc/passwd. L'obiettivo non era chiudere la porta, ma correggere il finding specifico relativo alla password "password".

Figura 6 - Prima della remediation: VNC attivo sulla porta 5900/TCP

```
(kali@kali)-[~]
$ nmap -sV -p 5900 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 03:56 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0016s latency).

PORT      STATE SERVICE VERSION
5900/tcp  open  vnc      VNC (protocol 3.3)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.80 seconds
```

Ho creato una copia di backup del file della password e ho eseguito vncpasswd per impostare una nuova credenziale. La versione di TightVNC presente su Metasploitable limita la password effettiva a 8 caratteri; per questo la nuova password è stata scelta rispettando tale limite.

- sudo cp /root/.vnc/passwd /root/.vnc/passwd.bak
- sudo vncpasswd /root/.vnc/passwd

La verifica è stata eseguita da Kali con vncviewer. La vecchia password "password" viene ora rifiutata, mentre la nuova credenziale consente l'autenticazione e l'apertura del desktop remoto. Il servizio rimane quindi disponibile, ma non utilizza più la password debole rilevata da Nessus.

Figura 7 - La vecchia password viene rifiutata dal server VNC

```
(kali@kali)-[~]
$ vncviewer 192.168.51.101:0
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure
```

Figura 8 - Autenticazione VNC riuscita con la nuova password

```
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure

(kali@kali)-[~]
$ vncviewer 192.168.51.101:0
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure

(kali@kali)-[~]
$ vncviewer 192.168.51.101:0
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's 3 desktop (metasploitable:0)"
VNC server default format:
  24 bits per pixel
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift
  Using default colormap which is TrueColor. Pixel fo
  24 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift

(kali@kali)-[~]
$ vncviewer 192.168.51.101:0
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's 3 desktop (metasploitable:0)"
VNC server default format:
  24 bits per pixel
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift
  Using default colormap which is TrueColor. Pixel fo
  24 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift

Workspac 1 62 Oct, 8:21:12
```

3. NFS Shares World Readable

La traccia indicava come riferimento NFS Exported Share Information Disclosure, mentre nella scansione reale Nessus ha rilevato NFS Shares World Readable. La configurazione NFS iniziale esportava la directory radice verso qualsiasi host. Da Kali, showmount -e mostrava “/ *” e gli script nfs-showmount e nfs-ls riuscivano a enumerare directory della root come bin, home, lib e usr.

Figura 9 - Prima della remediation: export / * ed enumerazione remota del filesystem

```
(kali@kali)-[~]
$ showmount -e 192.168.51.101
Export list for 192.168.51.101:
/ *

(kali@kali)-[~]
$ nmap -p 111,2049 --script nfs-showmount,nfs-ls 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 04:22 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0028s latency).

PORT      STATE SERVICE
111/tcp   open  rpcbind
|_nfs-ls: Volume /
|_access: Read Lookup Modify Extend Delete NoExecute
|_PERMISSION UID GID SIZE TIME FILENAME
|_drwxr-xr-x 0 0 4096 2012-05-14T03:35:33 bin
|_drwxr-xr-x 0 0 4096 2010-04-16T06:16:02 home
|_drwxr-xr-x 0 0 4096 2010-03-16T22:57:40 initrd
|_lrwxrwxrwx 0 32 2010-04-28T20:26:18 initrd.img
|_drwxr-xr-x 0 0 4096 2012-05-14T03:35:22 lib
|_drwx----- 0 16384 2010-03-16T22:55:15 lost+found
|_drwxr-xr-x 0 0 4096 2010-03-16T22:55:52 media
|_drwxr-xr-x 0 0 4096 2010-04-28T20:16:56 mnt
|_drwxr-xr-x 0 0 4096 2012-05-14T01:54:53 sbin
|_drwxr-xr-x 0 0 4096 2010-04-28T04:06:37 usr
|_nfs-showmount:
|_ / *
2049/tcp open  nfs

Nmap done: 1 IP address (1 host up) scanned in 0.87 seconds
```

Sul target il file /etc/exports conteneva la riga / *(rw,sync,no_root_squash,no_subtree_check). Dopo aver creato una copia di backup, ho commentato la riga e applicato nuovamente la configurazione con exportfs -ra.

Figura 10 - Configurazione NFS iniziale con export della root verso tutti gli host

```
msfadmin@metasploitable:~$ cat /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
# to NFS clients. See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4 gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
# *(rw,sync,no_root_squash,no_subtree_check)
```

```
sudo cp /etc/exports /etc/exports.bak
```

```
sudo exportfs -ra
```

La verifica successiva mostra che l’elenco degli export è vuoto. Nmap rileva ancora i servizi rpcbind e NFS sulle porte 111 e 2049, ma lo script nfs-showmount restituisce “No NFS mounts available” e non è più possibile enumerare la root.

Figura 11 - Dopo la remediation: nessun export NFS disponibile

```
(kali@kali)-[~]
$ showmount -e 192.168.51.101
Export list for 192.168.51.101:

(kali@kali)-[~]
$ nmap -p 111,2049 --script nfs-showmount,nfs-ls 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 04:28 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0017s latency).

PORT      STATE SERVICE
111/tcp   open  rpcbind
|_nfs-showmount: No NFS mounts available
2049/tcp open  nfs

Nmap done: 1 IP address (1 host up) scanned in 0.81 seconds
```

4. rexecd Service Detection

Il servizio rexecd risultava in ascolto sulla porta 512/TCP. Nel file /etc/inetd.conf era presente la voce exec stream tcp nowait root /usr/sbin/tcpd /usr/sbin/in.rexecd, mentre Nmap riportava 512/tcp open exec?.

Figura 12 - Prima della remediation: rexecd configurato e porta 512 in ascolto

```
msfadmin@metasploitable:~$ grep -n "exec" /etc/inetd.conf
7:exec      stream tcp      nowait root    /usr/sbin/tcpd  /usr/sbin/in.rexecd
msfadmin@metasploitable:~$ netstat -tulpn | grep 512
tcp        0      0 0.0.0.0:512          0.0.0.0:*          LISTEN
```

Figura 13 - Nmap conferma la porta 512/TCP aperta

```
(kali@kali)-[~]
$ nmap -sV -p 512 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 04:29 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0016s latency).

PORT      STATE SERVICE VERSION
512/tcp   open  exec?

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.63 seconds
```

Ho creato una copia di backup di /etc/inetd.conf, commentato esclusivamente la riga relativa a exec e riavviato xinetd. Non è stato necessario cancellare il binario in.rexecd: la remediation consiste nel non esporre più il servizio tramite il superserver.

```
sudo cp /etc/inetd.conf /etc/inetd.conf.rexecd.bak
```

```
sudo /etc/init.d/xinetd restart
```

Figura 14 - Voce exec commentata nel file /etc/inetd.conf

```
GNU nano 2.0.7      File: /etc/inetd.conf      Modified
#<off># netbios-ssn  stream tcp      nowait root    /usr/sbin/tcpd  /usr/sbin/
telnet             stream tcp      nowait root    /usr/sbin/tcpd  /usr/sbin/in.telnetd
#<off># ftp          stream tcp      nowait root    /usr/sbin/tcpd  /usr/sbin/ft
lftp              dgram udp        wait  nobody /usr/sbin/tcpd  /usr/sbin/in.lf
shell             stream tcp      nowait root    /usr/sbin/tcpd  /usr/sbin/in.r
login            stream tcp      nowait root    /usr/sbin/tcpd  /usr/sbin/in.r
exec              stream tcp      nowait root    /usr/sbin/tcpd  /usr/sbin/in.re
mingreslock stream tcp nowait root /bin/bash bash -l
```

Dopo il riavvio netstat non mostra più la porta 512 in ascolto e Nmap la identifica come closed. Questo conferma che rexecd non è più esposto alla rete.

Figura 15 - Dopo la remediation: porta 512/TCP chiusa

```
(kali@kali)-[~]
$ nmap -sV -p 512 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 04:38 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0083s latency).

PORT      STATE SERVICE VERSION
512/tcp   closed exec

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.90 seconds
```

5. Remediation facoltativa: rlogin tramite pfSense

Come quinta prova ho scelto rlogin, servizio legacy rilevato sulla porta 513/TCP. Prima della modifica Nmap mostrava la porta come open login?. In questo caso ho utilizzato una regola firewall, mantenendo il servizio presente sulla macchina ma impedendone l'accesso dalla rete di Kali.

Figura 16 - Prima della regola firewall: rlogin raggiungibile sulla porta 513/TCP

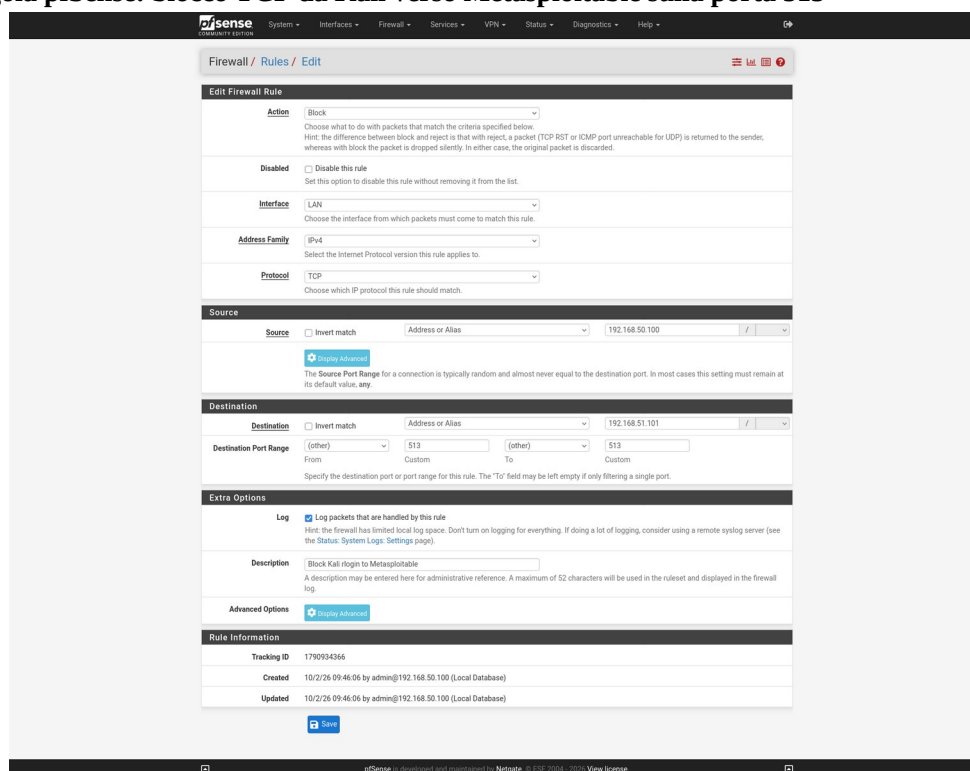
```
(kali㉿kali)-[~]
$ nmap -sV -p 513 192.168.51.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-02 05:37 -0400
Nmap scan report for 192.168.51.101
Host is up (0.0019s latency).

PORT      STATE SERVICE VERSION
513/tcp    open  login?

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.83 seconds
```

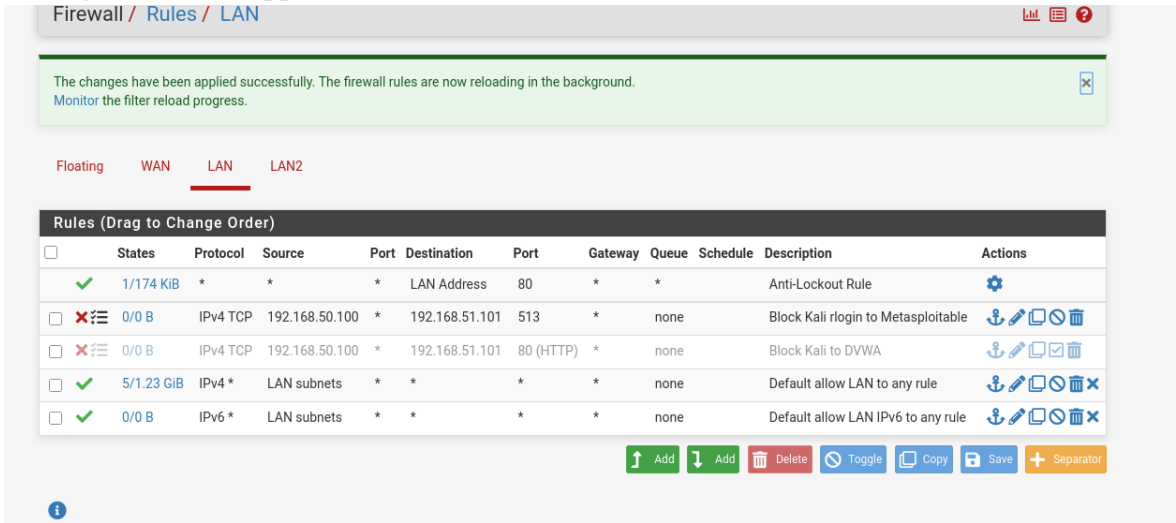
La regola è stata inserita sull'interfaccia LAN di pfSense, cioè l'interfaccia dalla quale entra il traffico generato da Kali (192.168.50.100). La destinazione è Metasploitable (192.168.51.101), protocollo TCP e porta 513. Il logging è stato abilitato per avere una seconda evidenza del blocco.

Figura 17 - Regola pfSense: blocco TCP da Kali verso Metasploitable sulla porta 513



La regola è stata posiziona sopra la regola generale "Default allow LAN to any rule", in modo che il blocco venga valutato prima del permesso generale.

Figura 18 - Regola di blocco applicata sull'interfaccia LAN



Dopo l'applicazione della regola Nmap restituisce 513/tcp filtered login. Il log firewall mostra inoltre i pacchetti TCP provenienti da 192.168.50.100 e diretti a 192.168.51.101:513 gestiti dalla regola “Block Kali rlogin to Metasploitable”. Questa è una mitigazione a livello di rete: il servizio non è stato rimosso dal target, ma non è più raggiungibile dal segmento utilizzato per la scansione.

Figura 19 - Dopo la remediation: porta 513/TCP filtrata

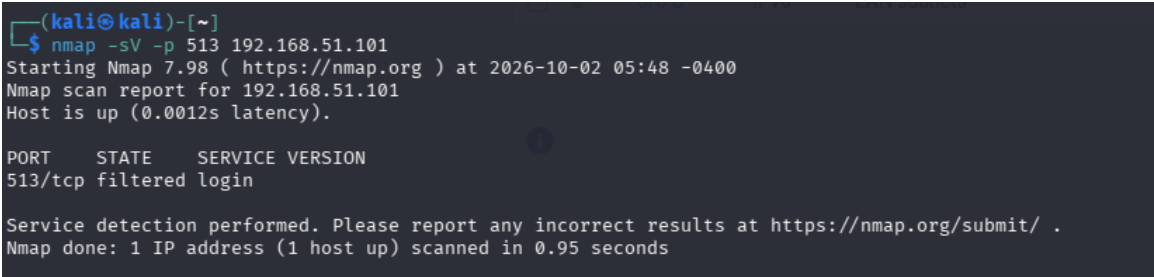


Figura 20 - Log pfSense che conferma il blocco dei tentativi verso 513/TCP

✗	Oct 2 09:48:01	LAN	Block Kali rlogin to Metasploitable (1790934366)	192.168.50.100:38494	192.168.51.101:513	TCP:S
✗	Oct 2 09:48:02	LAN	Block Kali rlogin to Metasploitable (1790934366)	192.168.50.100:38496	192.168.51.101:513	TCP:S

6. Riepilogo delle modifiche

Finding	Prima	Dopo
Bind Shell Backdoor Detection	1524/tcp open; shell root senza autenticazione	1524/tcp closed; connessione Netcat rifiutata
VNC Server 'password' Password	Password “password” valida	Vecchia password rifiutata; nuova password valida
NFS Shares World Readable	Export / * e filesystem enumerabile	Nessun NFS mount disponibile
rexecd Service Detection	512/tcp open	512/tcp closed
rlogin Service Detection	513/tcp open	513/tcp filtered tramite pfSense

Le verifiche manuali sono state eseguite prima della nuova scansione Nessus, così da controllare immediatamente l'effetto delle modifiche. La conferma finale dei finding viene riportata nel documento W12D4_ScansioneFine.